

第07章 網路安全概論

基礎架構、常見威脅手法與危機應變體系

SECURITY

本章地圖：三大主題



7.1 網路基礎架構

通訊系統、TCP/IP 分層協定、IP 定址與關鍵通訊埠機制。



7.2 網路安全威脅

駭客工具演變、常見攻擊型態與 DoS/DDoS 阻斷服務攻擊。



7.3 網路危機處理

日常防禦紀律、SOC 維運中心監控與 CERT 緊急通報團隊。

三大核心單元 · 循序漸進



電腦網路：主機間的溝通系統



網路（Network）

透過中繼設備、實體線路與通訊協定連結不同主機，達到訊息傳遞與硬體軟體資源共享。



網際網路（Internet）

連結全球無數主機的龐大系統，由無數區域網路（LAN）與廣域網路（WAN）相互串聯成網。

企業網路架構一覽

路由器、交換器、伺服器與防火牆各司其職，共同建構企業內外網通訊骨幹。



防火牆

邊界防護：管制內外網進出流量，阻擋未授權存取與惡意連線。



路由器

路徑指引：連接不同網段，負責跨網封包最佳傳輸路徑路由選擇。



交換器

內部交換：於區域網路內高速轉發數據框架至目標實體主機。



伺服器

核心服務：提供網頁、資料庫、郵件與認證等企業核心應用資源。

分工協作 • 邊界與縱深防禦基礎

協定分層：化繁為簡

將複雜的網路通訊流程模組化，讓各層獨立運作與除錯，降低設計難度。

OSI 七層參考模式

國際標準化組織（ISO）提出的學術架構，作為通用觀念模型與標準化參照規範。



學術標準框架

應用、表現、會議、傳輸、網路、資料連結、實體層



嚴密定義細節

分工精細但實作較繁瑣，現多用於概念解說與除錯參照

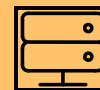
TCP/IP 五層實務協定組

因應實務建置而生的工業標準，也是當今網際網路真正運作的技術骨幹。



工業實務首選

精簡架構，將應用相關層級整合，效率高且擴充彈性佳



現代網路骨幹

所有現代作業系統與網路硬體皆以此標準為基礎構建

TCP/IP 五層協定，由下而上

各層專司其職，由實體訊號傳輸層層封裝，最終交付給應用程式服務。



1. 實體／連結層

硬體與訊號：網卡 MAC 定址、乙太網路訊框，負責實體媒介訊號傳送。



2. 網路層

定址與路由：核心協定為 IP 與 ICMP，負責決定跨網封包最佳傳輸路徑。



3. 傳輸層

端對端通訊：TCP 與 UDP 協定，負責主機處理程序之間的流量與連線控制。



4. 應用層

使用者服務：HTTP、HTTPS、FTP、SMTP、DNS 等直接提供給終端的協定。

資料封裝封包化 • 階層式資料傳遞

IP 定址：從 IPv4 到 IPv6

IPv4

32 位元架構

32 位元，四組十進位數字如 XXX.XXX.XXX.XXX，位址已不敷使用



約 43 億個位址上限

全球公有 IPv4 已宣告發放耗盡。



NAT 暫時緩解

目前廣泛依賴私有虛擬 IP 與 NAT 轉換支撐運作。

IPv6

128 位元架構

128 位元，8 組十六進位數字以冒號分隔，解決位址短缺問題



近乎無窮盡的空間

提供約 3.4×10^{38} 個位址，解決位址短缺問題。



內建現代安全性

原生支援 IPsec 加密與驗證機制，提高資料傳輸防護。

傳輸層雙主角：TCP 與 UDP

TCP

傳輸控制協定

可靠傳輸首選：重視數據正確性與完整度，適用於網頁、檔案與郵件傳遞。



三向交握機制

傳輸前必須進行 SYN → SYN/ACK → ACK 建立連線。



錯誤重傳與流量控制

確認封包到達順序，遺失自動重傳，開銷較大。

UDP

用戶資料報協定

高速串流首選：不建立連線直接發送，適用即時影音、語音與線上遊戲。



非連線型極速傳輸

無交握延遲，僅附帶連接埠資訊即送出封包。



不保證送達與順序

掉包不重傳、無流量反饋，結構簡單且開銷極低。

連接埠：服務的專屬門牌

如果 IP 是主機的地址，連接埠（Port）就是主機上各應用服務的專屬分機號碼。



80 HTTP 網頁服務

一般全球資訊網（Web）
傳輸標準未加密通訊門
牌。



443 HTTPS 安全加 密

具備 SSL/TLS 加密傳輸
機制的現代網頁安全標準
門牌。



20 / 21 FTP 檔案傳輸

21 埠負責連線控制指
令，20 埠負責實際數據
內容傳輸。



22 / 23 遠端管理連線

22 埠為 SSH 安全加密連
線；23 埠為明文 Telnet
傳統管理。

ICMP 與 Ping：網路的健康檢查

ICMP 提供網路層狀態回報；Ping 工具發出 request 並等待 reply，藉此確認連線狀況。



1. 發送請求

客戶端送出 ICMP Echo Request（型態 8）訊號封包探測目標。



2. 伺服器端回應

若目標存活且未阻擋，便回傳 ICMP Echo Reply（型態 0）。



3. 健康指標分析

計算封包來回時間（RTT）與丟包率，評估線路穩定與連通品質。

網路診斷利器 • 但亦常遭攻擊者利用發動 Smurf 攻擊



Chapter 7.2

7.2 網路安全威脅

從攻擊工具普及、常見威脅型態到阻斷服務癱瘓手法

THREATS

攻擊工具唾手可得

61%

攻擊工具包佔比

網頁安全威脅事件中，有高達 61% 攻擊事件直接採用現成攻擊工具包發動。

模組化與自動化套件盛行

攻擊者不再需要精通底層協定與撰寫程式，只要下載圖形化工具包即可進行探測與滲透。

暗網黑市商業化運作

網路犯罪形成完整產業鏈（Crime-as-a-Service），提供按次付費與一鍵攻擊租賃服務。

防禦難度幾何級數攀升

攻擊方成本極低而防禦方必須確保每個節點安全，資安防禦面臨嚴峻的非對稱對抗。

攻擊門檻大幅下降 • 腳本小子威脅倍增

四大常見攻擊類型

針對人類弱點、傳輸中途、系統漏洞與深層潛伏等不同維度展開進攻。



網路釣魚

Phishing：發送假冒官方郵件或架設偽裝網站，誘騙使用者交出帳密與信用卡資安憑證。



中間人攻擊

MitM：潛伏在通訊兩端之間攔截、竄改甚至偽裝成對方身分傳遞虛假封包資訊。



進階持續性威脅

APT：具特定商業或政治目標，長期暗中潛伏、精心策劃並持續滲透的組織性入侵。



零時差攻擊

Zero-Day：趁原廠發布安全性修補程式（Patch）前的時間差，突襲利用已知漏洞搶先攻擊。

社交工程 • 傳輸攔截 • 組織潛伏 • 漏洞搶攻

阻斷服務攻擊：癱瘓可用性

DoS

單點發動，使伺服器無法正常服務



DDoS

多台受控「殭屍電腦」同時發動攻擊



攻擊目標：打破 CIA 三要素中的「可用性（Availability）」

五種常見癱瘓手法

01 TCP SYN Flood

利用三次交握弱點，偽裝來源發送大量 SYN 請求卻不回應 ACK，佔滿伺服器連線佇列使其癱瘓。

02 UDP Flood

向目標主機的大量隨機通訊埠發送龐大 UDP 封包，逼迫系統耗費龐大運算回覆 ICMP 連接埠不可達訊息。

03 Ping of Death

傳送超過 65,535 位元組的超大型畸形 ICMP 封包，目標主機在重組封包時導致緩衝區溢位或直接崩潰。

04 Smurf 攻擊

偽造受害者的 IP 位址向廣播網段發送 Ping 請求，引導整個網段所有主機回覆 Echo Reply 圍攻受害者。

05 緩衝區溢位 (Buffer Overflow)

輸入超量資料塞爆記憶體堆疊 (Stack)，覆蓋記憶體控制指令導致系統異常執行或當機。



Chapter 7.3

7.3 網路安全危機處理

日常維運紀律、SOC 全時監控中心與 CERT 緊急應變救援

RESPONSE

危機處理的日常紀律

良好的日常基本防禦習慣，能有效杜絕 80% 以上常見網路攻擊與威脅風險。



追蹤情資公告

隨時掌握威脅：密切關注 CERT、TWCERT-CC 等權威資安機構發布之最新漏洞預警與零時差修補建議。



即時修補程式

及時更新 Patch：建立標準更新派送程序，縮減漏洞暴露窗口，搶在駭客發動零時差攻擊前完成修補。



紀錄過濾與分析

嚴格檢視軌跡：定期檢閱伺服器與防火牆日誌（Log），關閉閒置連接埠，阻絕一切不必要的對外連線。

資安無捷徑 • 重在基本功與嚴謹執行力

SOC：資訊安全監控維運中心

Security Operations Center：整合企業資安政策、防護設備與應變團隊的統一中央管制中樞。



資安政策整合

將企業內部資安管理規範與各項合規制度標準轉化為具體可落實的監控基準。



防護技術協同

連線匯聚防火牆、IDS/IPS、防毒與 EDR 等跨品牌防禦系統日誌統一關聯。



統一全天候監控

建置集中式管制中心，實施 24×7 零死角全天候即時流量與異常威脅評估。



緊急聯防反制

一旦觸發高危險事件即刻啟動跨部門告警，第一時間隔離受害端點遏止災情擴大。

企業資訊神經中樞 • 集中可視化與快速打擊體系

SOC 五大主要功能

涵蓋資安生命週期的事前、事中與事後三大階段，形成閉環防護體系。

事前 主動預防管理

在威脅落地前阻斷攻擊路徑與排除系統缺陷。



資安警訊管理

情資情勢分析與通報發布

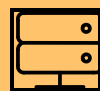


資安弱點管理

定時弱點掃描與修補稽核

事中 即時動態監看

全天候掌握防護設備健康度與網路異常行為。



資安設備管理

規則派送與健康狀況維運



資安事件監看

即時告警分析與可疑關聯

事後 事故緊急處理

災難發生後的快速止血、根因追蹤與防護強化。



事故應變處理

緊急封鎖、調查與止血復原



調查與根因分析

留存鑑識證據與回饋規則

事前預防 · 事中監看 · 事後處理

CERT：危機發生時的救援隊

1988

莫里斯蠕蟲事件

首個癱瘓全美 10% 網際網路主機的重大事件，促成首座 CERT 應運而生。



重大事故專家應變

由資深專家組成第一線救援隊，於重大入侵危機發生時進駐協助止血分析與復原。



全球跨國情資聯防

各國與企業相繼成立 CERT（如台灣 TWCERT-CC），彼此即時共享攻擊情資與威脅對策。

電腦緊急應變小組 • 專家聯防支柱

本章重點回顧

掌握網路底層邏輯、辨識常見攻擊弱點，並落實企業縱深防護紀律。



1. 網路底層運作

網路依賴 TCP/IP 分層架構封裝、IP 定址導航與 Port 服務門牌實現穩定通訊。



2. 多元威脅手法

攻擊型態自資料竊取延伸至 DoS/DDoS 癱瘓，濫用協定弱點造成可用性危機。



3. 危機處理雙支柱

SOC 承擔 24×7 監控維運中樞，CERT 提供重大入侵緊急專家救援與情資共享。